HEALTHWITHSEVGI

FINAL SHOWCASE
ISO/IEC 42001:2023
EU AI ACT

An ML-literacy pipeline for healthcare professionals.
Twenty specialties · seven steps · six models · nothing stored.

Health. With. Sevgi.

SENG 430 / SOFTWARE QUALITY ASSURANCE / ÇANKAYA UNIVERSITY / SPRING 2026

DR. SEVGI KOYUNCU TUNÇ

TEAM · ISO 42001 GOVERNANCE

Each Scrum role on this team is also a named ISO 42001 governance role.

SCRUM ROLE		MEMBER	ISO 42001 GOVERNANCE ROLE	CLAUSE
Product Owner	→	**Efe Çelik**	AI System Owner	Cl. 5.1
Tech Lead · Scrum Master	→	**Batuhan Bayazıt**	Technical Lead	Cl. 5.3
Developer · Backend	→	**Berat Mert Gökkaya**	Data Steward	A.6.2–6.4
UX Designer	→	**Burak Aydoğmuş**	Ethics & UX Reviewer	A.8.3
QA · Documentation Lead	→	**Berfin Duru Alkan**	QA & Compliance Lead	Cl. 9.2

THE SYSTEM AT A GLANCE

Twenty clinical specialties. One disciplined pipeline.

20.

Each specialty ships with a real, de-identified clinical dataset and a 7-step wizard. **Six classifiers** *are tunable.* **Nothing is stored on the server.**

01 CONTEXT · 02 EXPLORE · 03 PREPARE · 04 MODEL · 05 RESULTS · 06 SHAP · 07 ETHICS

6 ML MODELS **8** EU AI ACT ITEMS **0** PERSISTENT ROWS

ISO/IEC 42001:2023 — COVERAGE

Cl. 4 Context | Cl. 5 Leadership | Cl. 6 Risk | Cl. 8 Operation | Cl. 9 Performance

A.5 Lifecycle | A.6 Data | A.7 Recording | A.8 Use | A.9 Third-party

WHY OUR LEAD METRIC IS SENSITIVITY

ISO 42001 IN PRACTICE

> *A clinician must always decide whether and how to act on an AI prediction.*

— STEP 6 DISCLAIMER · ISO 42001 PRINCIPLE 3 (HUMAN OVERSIGHT)

WHAT THE POLICY CHANGED

A **90 %-accurate** model can still miss every patient about to crash. Principle 3 told us the headline metric must align with oversight, not with the model. We led with **sensitivity** — not accuracy.

WHY THIS PROJECT, NOT JUST ANY PROJECT

Healthcare AI is classified **high-risk** under EU AI Act Annex III. Choosing a headline metric isn't taste — it is a documented, auditable governance decision. Ours is in our AI Policy.

UNDERNEATH THE HEADLINE

Seven more numbers that frame the 79 %.

83.3%	82.2%	71.4%	75.0%	84.5%	0.627	99.6%
ACCURACY	SPECIFICITY	PRECISION	F1 SCORE	AUC-ROC	MCC	TRAIN

THRESHOLD TUNING

Default 0.50 → 0.15. Adjusted to maximise F1 for this class distribution.

CROSS-VALIDATION

AUC = 0.909 ± 0.040 across 15 folds — the honest performance number.

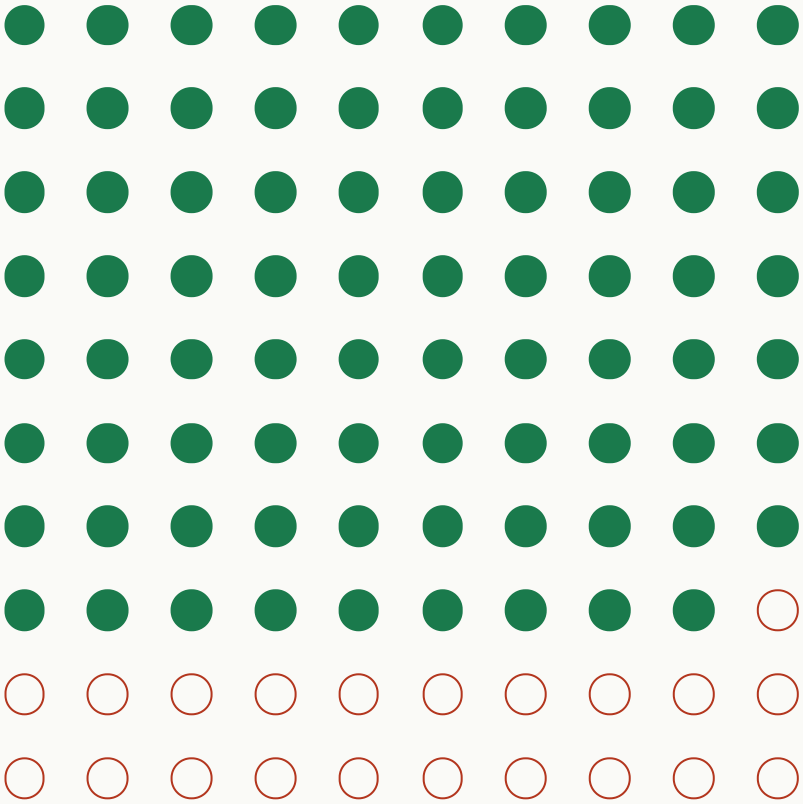
> *"In trees, near-perfect train accuracy is normal. We report the cross-validation AUC as the honest performance signal — and the test sensitivity as the clinically actionable one."*

WHY OUR POLICY AUDITS BY SUBGROUP

Twenty-one looked fine. Until they didn't.

79 ● on time

21 ○ too late



ISO 42001 names patients an indirect affected party. They don't sit at our metric review. The twenty-one do, here.

WHAT WE LEARNED

FINDING 01 OF 04

§ 1.2 — OUT OF SCOPE

"Out of Scope" killed feature creep before we noticed we had any.

We had been quietly piling on deep learning, regression, and a multilingual UI. Writing the **WHY** column in the Out-of-Scope table forced us to cut all three — and committed us to interpretable, SHAP-friendly classical ML.

> *"Deep learning would undermine the educational objective of transparency."*
>
> — § 1.2 — OUT OF SCOPE

WHAT WE LEARNED

FINDING 02 OF 04

§ 2.1 · PRINCIPLE 4 — PRIVACY

Privacy-by-design wasn't a paragraph — it was an architecture migration.

THE MIGRATION

BEFORE ~~External database — persistent storage~~

↓

AFTER **In-memory · OrderedDict LRU**

— § 1.3 → § 2.1 · PRINCIPLE 4

We started planning with a database. Writing Principle 4 forced the rewrite to in-memory + LRU eviction. While drafting § 1.3 we caught an unbounded `DataService` dict bug — now logged as a Chapter 4 risk.

A.6.3 · A.9.4 — DATA & THIRD-PARTY

A licensing audit flipped two datasets out of our Docker image.

Stroke (Kaggle) and Anaemia (Kaggle) couldn't be verified for redistribution rights. Without the audit we would have shipped a license violation. Both now auto-download at runtime.

TWENTY DATASETS · THE AUDIT

18 bundled in Docker

2 runtime download · license unverified

WHAT WE LEARNED

FINDING 04 OF 04

§ 1.4 — STAKEHOLDER REGISTER

"Patients as indirect parties" is the line that gave us age-band fairness.

> *"Severity × reversibility — a missed elderly diagnosis is not a reversible inconvenience."*
>
> — § 4.2.1 — IMPACT ASSESSMENT

The original plan checked gender fairness only. The Stakeholder Register listed patients as an indirect *affected* party — that single phrase made us add the **18-60 / 61-75 / 76+** band split. It is the line our 10 pp-gap warning watches at runtime.

Q&A

Thank you. We're listening.

LIVE DEMO · GITHUB · JIRA · FIGMA